



SENTRIX CORE

GRADUATION PROJECT · FACULTY OF COMPUTERS AND ARTIFICIAL INTELLIGENCE

Security Plan and Threat Model

A staged security document for the SENTRIX CORE personal-safety system: what must be protected, who can reach it, and what the project will do at each stage of development.

Alryada University

Prepared by Nourseen Tarek

October 2026 · Academic submission

Status: security documentation for a project still in development. The wearable and the full ecosystem are not deployed.

1. Why this document exists

SENTRIX CORE is a personal-safety system. In its intended form it watches motion, health-related signals, sound, and location, and it can raise an emergency alert. Those are sensitive functions. A mistake can expose where a person is, expose health or audio information, or send a false alert to emergency services.

This document is the project security chapter. It has two parts. The **security plan** says what the team will do to reduce those risks, stage by stage. The **threat model** says what is worth protecting, who could reach it, and what harm that would cause.

This is a written plan for the graduation project. It is not a statement that a commercial product is already secure, and it is not a statement that the wearable has been built. Controls are marked as current work, prototype work, planned hardware, or future system behavior.

1.1 How to read the stages

Stage	What it is	Security meaning
Current	Mobile and software work, and AI experiments on datasets that already existed.	Protect project files and be accurate about data. Do not contact real emergency services from a demo.
Prototype	Development kits used to test sensors, the processor, Bluetooth, and cellular.	The kit is laboratory equipment. Debug access is expected and must be labeled as such.
Planned hardware	A custom band, if it is finished before the demonstration, following the Hardware Design Specification.	Physical SOS button, controlled firmware update, and no claim of a secure element that is not on the board.
Future system	Cloud, guardians, nearby helpers, evidence, and operator or administrator dashboards.	Specified in the research paper. Not deployed. Access rules below are a recommendation until the team approves them.

1.2 Hardware direction used by this plan

The current hardware direction is the Hardware Design Specification: nRF5340, nRF9151, BMI270, MAX86176, MAX30208, IM69D130, nPM1300, a physical SOS button, Bluetooth Low Energy, LTE-M/NB-IoT, and GNSS. That specification is a pre-schematic design. It is not a built device.

An earlier hardware description in Section 13 of the research paper used a different processor, modem, and a secure element (NXP SE050). That description is kept as design history. This plan does not add a secure element, because the current bill of materials does not include one.

2. Security plan

The plan follows the work the team can actually do. It does not treat a screen drawn in the research paper as a finished security feature.

2.1 Current stage — software and AI experiments

- Experiments use pre-existing datasets collected by other parties, including public research sets. The team did not collect GPS, audio, medical, or child data from real users for these experiments.
- Those files stay separate from any future records of real SENTRIX users. The project report must describe them as externally collected datasets.
- Dataset name, source, and license are recorded before a file is placed inside a demonstration package. A license that has not been read is not described as permission to redistribute the file.
- Passwords, API keys, and private keys are not written into source code. Raw dataset copies and model binaries are kept out of the Git repository.
- A demonstration SOS control stays inside the project. It does not call, text, or packet a real emergency service unless the team makes a separate, explicit decision to do so.
- When the mobile application source is reviewed, any stored token is moved to the phone's secure storage, sessions end on logout, and server connections are recorded and kept off cleartext HTTP.

The mobile application is under development. Its source was not in the project folder inspected for this document, so login, storage, and network behavior are requirements for that code, not features already verified here.

2.2 Prototype stage — development kits

- Each kit is labeled as a laboratory prototype, not as the finished SENTRIX band.
- Signals on the kit are bench signals, externally collected files, or replay. A live stream of a real person's location or voice is not used.
- Programming and serial debug ports may stay open on a kit. That fact is written in the lab notes. The same open port is not later described as a closed product.
- The serial link to the cellular modem is disconnected at the end of a session. SIM credentials are not printed in logs.
- Bluetooth pairing is chosen and written down before a phone is paired. Until that choice exists, a Bluetooth test is only a connectivity test.
- A live cellular subscription is used only after an explicit decision. The lab configuration does not contain a real emergency-service address.

2.3 Planned stage — custom wearable

These items apply only if a custom board is built. They are acceptance checks, not completed work.

- The physical SOS button is debounced in firmware and does not depend on an AI model. That matches the Hardware Design Specification.
- Before the board is presented as product-like, the team records whether boot checks the firmware image, and whether debug pads are removed, locked, or left as an accepted engineering risk.
- Key storage is named honestly. If no secure storage is used, the report says so. TrustZone on the nRF5340 is a chip capability. It is not in use until a firmware split is designed.
- A failed firmware update must still leave the local SOS button able to be detected. Sending that press off the device can wait until the radio recovers.
- Factory reset clears Bluetooth bonds and local logs and still leaves the SOS button working.

2.4 Future stage — full SENTRIX CORE ecosystem

The research paper describes guardians, a Nearby Rescue Network, evidence storage, an operator dashboard, and an administrator dashboard. Those parts are not deployed. Before they are built, the project needs an approved access rule, authenticated emergency messages, a retention period, and a deletion rule. No cloud vendor is chosen in the project documents, and this plan does not invent one.

2.5 Emergency behavior

Topic	What the project documents say	What this plan requires
Starting an alert on the planned hardware	A physical SOS button, independent of the AI decision.	Use that button as the hardware start control. It is not built yet.
Touch gestures in the research paper	Section 7.2, Section 13.10, and one case study disagree about the same presses.	Treat those maps as an unresolved design conflict. Do not implement them as the security rule.
Who may cancel an alert	Not settled, once the gesture conflict is set aside.	A written cancel policy is required before an emergency demonstration.
Silent emergency, helpers, operators	Described in the research paper.	Future behavior. Not implemented.
Real emergency services	Case studies show guardian authorization. One screen describes a simulation that does not dispatch.	The academic demonstration does not contact a real service unless that decision is made separately.

2.6 Privacy

Two data classes stay separate.

- **Current research data.** Copies of datasets collected by external sources. The team is not the collector. Source terms still have to be read before redistribution. This document does not claim that those terms have been satisfied.
- **Future SENTRIX user data.** Location, audio, health-related signals, and possible data about children or other dependents, collected by a future deployment. That data does not exist in the current experiments.

The project is being developed in Egypt. A future system that processes personal data of real people would need a privacy assessment under Egypt's Personal Data Protection Law, Law No. 151 of 2020. That assessment is not done in this document, and this document is not legal advice. GDPR and HIPAA are reference names only. The project documents do not establish that either law applies, and this plan does not claim compliance with them.

2.7 Recommended access rules

The team has not approved every permission. The table below is a recommendation for approval. It is not an implemented feature. It follows least privilege: a person receives only the access the task needs. An administrator manages the platform and does not receive routine access to user content.

Data or action	User	Guardian	Nearby helper	Medical helper	Operator	Administrator
Own profile and health profile	Own	No	No	No	No	No content
Live location	Own	Linked person, if granted	Approximate only until they accept; precise only during that incident	Same as helper	Assigned incident only	No
Location history	Own	Only if granted	No	No	Incident window	No
Heart rate, SpO2, ECG	Own	Only if granted	No	During an accepted incident	Assigned incident	No
Audio or video	Own	Only if granted for that incident	No	No	Assigned incident	No
Start SOS	Own	No	No	No	No	No
Cancel an active alert	Own, after a written policy	Not by default	No	No	No	No
Firmware and model updates	No	No	No	No	No	Yes, with a recorded action

ECG applies only if the MAX86176 path in the Hardware Design Specification is built. Helper and operator access ends when the incident closes. A future child profile, if added, is owned by the linked guardian under this recommendation.

3. Threat model

A threat model names the things that matter, the people who could reach them, and the damage if they do. Threats that belong to a later stage are labeled. They are not claimed to be happening now.

3.1 Assets

Current project assets

Asset	Why it matters
Design documents and this security chapter	They are the academic record of the system.
Copies of externally collected datasets	They may be restricted by the original source. They are not data the team collected from users.
Trained models and experiment results	Unpublished academic work, once those files exist on team machines.
Mobile application source	Under development. Any accounts or tokens inside it must be reviewed with the source.

Future SENTRIX assets

These are specified by the research paper or the hardware direction. They are not deployed.

Asset	Examples
Identity	Accounts, sessions, guardian links, helper identity
Location	Live position, route history, safe zones
Body and voice	Heart rate, SpO2, ECG if built, audio, video evidence
Behavior model	Digital Twin routines and places
Safety state	Emergency status, SOS, incident record
Device trust	Firmware, on-device models, Bluetooth bond, SIM or eSIM profile

3.2 Who could cause harm

Person	When this is realistic
Someone with a copy of the project files or a shared computer	Now
Someone with physical access to a development kit and its debugger	Prototype
A nearby Bluetooth radio during a kit test	Prototype
Someone who loads unofficial firmware, or fakes a sensor reading on the bench	Prototype and planned hardware
Someone who steals a future phone or band	Later
A nearby helper, guardian, or administrator who sees more than their role allows	Later

An attack on a live public cloud or on a fleet of production SIM cards is outside the current academic stage. Those cases stay in the future column so they are not forgotten. They are not current operating threats.

3.3 Important threats

ID	Threat	Stage	Impact
T1	External datasets are described as data the team collected, or mixed with future user records.	NOW	The project record is wrong, and a later privacy review starts from the wrong data.
T2	A restricted dataset is copied into the demonstration application.	NOW	Possible breach of the source terms. Licenses are not verified in this document.
T3	A password or API key is committed once source code is added.	NOW	Credential theft. A scan of this project folder found no source secrets.
T4	Unpublished models are copied from an unprotected machine.	NOW	Loss of academic work.
T5	An open debug port on a kit is later described as a finished product.	PROTOTYPE	Firmware and logs can be read or changed.
T6	Bluetooth is tested with no defined pairing.	PROTOTYPE	A nearby radio can attach to the lab device.
T7	The modem serial link is left open in the lab.	PROTOTYPE	Unwanted transmissions, including a false SOS.
T8	A real person's live location or audio is used on the kit.	PROTOTYPE	A lab test becomes processing of personal data.
T9	A demonstration SOS contacts a real emergency service.	DEMO	A false emergency.
T10	Debug remains open on a custom board shown as the product.	PLANNED	Same exposure as T5, on hardware that looks finished.
T11	Unofficial firmware runs on the custom board.	PLANNED	Safety logic can be removed. The boot check is not designed yet.
T12	A future phone or band is stolen.	FUTURE	Location and SOS continue until the device is unpaired. Unpair is not specified yet.
T13	A helper receives a precise location outside an accepted incident.	FUTURE	Tracking of a vulnerable person.
T14	A guardian or administrator account is used to read content the role does not need.	FUTURE	Broad disclosure of location, health, or audio.
T15	An unofficial model or firmware update is installed.	FUTURE	The wrong emergency decision. Update signing is not designed yet.
T16	A sensor reading is injected on the bench.	PROTOTYPE	A false fall, or a false "all clear." This is different from a broken sensor.
T17	The conflicting touch-gesture map is coded as the cancel rule.	ANY BUILD	An alert can be started or stopped by the wrong press.
T18	An evidence file and its hash can both be edited by the same person.	FUTURE	The stored hash no longer proves the file is unchanged.

3.4 What matters at this stage

The realistic work now is T1, T2, T3, and T4. Prototype threats T5 through T9 apply when a development kit is powered. Future threats stay in the requirements so the later design does not ignore them. They are not a description of a deployed system.

The single demonstration risk with immediate real-world harm is T9: a test SOS that leaves the lab and reaches a real emergency service. Until the team decides otherwise, demonstrations stay inside the project.

4. Risks still open

Rank	Risk
Critical	Mobile source must still be reviewed for login, storage, and network behavior.
Critical	The exact dataset files and their licenses are not listed in this document.
Critical	It is still undecided whether any demonstration may contact real emergency services.
High	Bluetooth pairing, the modem serial link, and debug policy are undecided, and kits are the next hardware step.
High	Who may cancel an alert is undecided, while the research paper contains conflicting gesture descriptions.
Medium	Key storage, secure boot, and remote update are not designed. The current bill of materials has no secure element.
Medium	The access table in Section 2.7 is a recommendation. It is not an approved requirement.
Low	TrustZone is unused. The report must not describe it as an active control.

5. Decisions the team still has to make

This plan does not close these decisions.

Decision	Why it matters
Which datasets are actually used, and what their licenses allow	Current privacy and a lawful demonstration package.
Whether the demo uses replayed or simulated data in addition to those datasets	Reviewers must be able to tell the data classes apart.
Whether a demo may use a live cellular network	A live registration can transmit from the laboratory.
Whether a demo may ever contact real emergency services	Prevents a false emergency.
Who may cancel an active alert	Prevents the wrong person from stopping a real alert.
Approve, edit, or reject the access table	Needed before guardian or helper accounts are built.
Which safety decisions later move onto the wearable	Phone-independent operation is only true for decisions that actually run on the band. Distress-audio and panic-voice models stay on the phone and cloud placements in the research paper until a decision moves them.
Bluetooth pairing method	Needed before the first phone-to-kit pairing is treated as secure.
Debug pads on a finished board	Open programming access on a product-like demo exposes the firmware.
Secure boot, update signing, TrustZone, and whether a secure element is ever added	Needed only when custom firmware is presented as product-like. No algorithm is chosen in this plan.

6. What to say in the examination

SENTRIX CORE will handle location, health-related signals, audio, and emergency alerts, so the project includes a security plan from the design stage. The plan is staged. Current experiments use externally collected datasets and must not send a real emergency alert. Development kits are laboratory tools. The custom band, if built, uses the physical SOS button in the Hardware Design Specification and does not claim a secure element that is not on that board. Guardians, nearby helpers, and cloud services are future architecture. Their access rules are written as a recommendation and are not yet a deployed control.

Supporting working files, kept with the project, are the detailed requirement matrix, hardware checklists, test plan, and decision register under the *security* folder. This PDF is the submission form of the security plan and the threat model.